

Litigation Exposure in Cybersecurity

Modes of Learning

For this course, the following modes of learning will be used:

- Interactive Module
- Textbook Readings
- Online Quizzes
- Written Reports
- Media

Introduction

Organizations that store, collect or use personal information are becoming victims of cybersecurity incidents (“cyber incidents”), where information is stolen or compromised due to an intentional or unintentional lapse(s) in data management. More than two dozen cyber incidents were publicly reported in Canada in 2016 alone. Often, these cases involve the theft of customers’ and/or employees’ personal information.

Once information is stolen, it is sold on the “dark web” for fraudulent purposes, held for ransom or even used for the physical destruction of corporate assets. Such incidents can force organizations to shut down systems, causing a loss of productivity, business and customer goodwill.

In an era when organizations face rapidly evolving cyberthreats, to avoid liability, organizations must keep pace with current legal trends. This module outlines the current legal trends that have significantly altered the privacy and cybersecurity landscape in Canada. The module is divided into two main sections: statutory framework and common law. The section on statutory framework describes the legislation relevant to privacy and cybersecurity issues; it is broadly divided into federal and provincial privacy legislation, and notes certain Criminal Code provisions that have been used to prosecute cybercriminals.

The section on common law describes the evolution of jurisprudence and its adoption of torts related to privacy claims. The two new torts of “intrusion upon seclusion” and “publicity given to private facts” are discussed in detail. Recent decisions that demonstrate the courts’ purposive and expansive approach in certifying privacy-related claims as class action are discussed.

Recent high-profile cases in Canada and the United States are also discussed, to demonstrate how cyber claims can be successfully brought by victims, financial institutions and shareholders.

As you begin this module, please refer to the timeline and make note of any assessments or important dates. If you have any questions, ask your instructor.

Learning Outcomes

Upon completion of this module, you will be able to:

1. Describe the provincial and federal statutory framework pertaining to cybersecurity in Canada.

2. Summarize recent criminal law and common law precedents that affect the interpretation of Canadian law when a cyber incident occurs.

Key Terms & Concepts

Listed below are some important key terms and concepts within this module.

- Privacy Act
- PIPEDA
- Digital Privacy Act
- Invasion of Privacy
- Mischief
- Intrusion Upon Seclusion
- Publicity Given to Private Facts

Statutory Framework: Federal

Federally, Canada has enacted two main privacy-related legislations: the Privacy Act and the Personal Information Protection and Electronic Documents Act (PIPEDA). The Privacy Act applies to federal organizations and their agencies that store, collect or use personal information. PIPEDA applies to private-sector organizations that handle personal information.

To regulate and oversee the implementation of these two statutes, Canada has created the Office of the Privacy Commissioner of Canada (OPCC).

60 per cent of participants say they do not expect to receive much privacy because of the multiple ways privacy can be infringed upon today.

Privacy Act and PIPEDA

The Privacy Act came into effect on July 1, 1983, and applies to federal organizations and their agencies that collect information about individuals, including their own employees. In brief, the Privacy Act mandates that the government only use information for the purposes for which it was collected.

Furthermore, the government must obtain consent from an individual before their information can be collected. The Privacy Act also gives people the right to access their collected information, and if they are obstructed from accessing that information, they can file a complaint with the OPCC.

PIPEDA came into effect on April 13, 2000, and applies to private-sector organizations that collect, use or store personal information for commercial activities across Canada. PIPEDA applies to federally regulated works, undertakings and businesses such as banks, airlines and telecommunication companies. It does not apply to private-sector organizations that do not engage in commercial activity, such as non-profits and charity groups. PIPEDA also does not apply in provinces that have legislation considered “substantially similar” to PIPEDA, unless personal information leaves the provincial boundary.

PIPEDA defines “personal information” as information about an identifiable individual, but does not include the name, title, business address or telephone number of an employee of an organization. PIPEDA gives individuals the right to expect that an organization collecting their information will ensure the

information is accurate, apply reasonable security standards to keep it confidential, and give the individual access to their information if necessary.

Digital Privacy Act

The Digital Privacy Act was passed by Parliament in June 2015 and amends PIPEDA in several ways, including the following:

- It requires organizations to keep and maintain a record of every breach of security safeguards that involves personal information under the organization's control.
- It requires organizations to notify certain individuals and organizations of security breaches that create a real risk of significant harm to the affected individuals and organizations. Organizations that experience such breaches must also report them to the OPCC.
- It enables the OPCC to issue fines of up to \$100,000 per violation for non-compliance with the above.

The Digital Privacy Act explains "real risk of significant harm" by describing factors that can determine whether a risk exists. These factors include the following:

The Digital Privacy Act explains "real risk of significant harm" by describing factors that can determine whether a risk exists. These factors include the following:

- "The sensitivity of the personal information involved in the breach."
- "The probability that the personal information has been, is being or will be misused."
- "Any including bodily harm, humiliation, damage to reputation or relationships, loss of enjoyment, business or professional opportunities, financial loss, identity theft, negative effects on credit rating and/or damage to or loss of property."

The Digital Privacy Act also sheds light on notification requirements. Notification to affected individuals and the OPCC must contain "sufficient information" for individuals to understand the significance of the breach and prepare to take necessary steps to mitigate possible harm. The notice should also be "conspicuous" and given directly to the individual if possible. Once regulations are finalized, there might be more specific information released about notification requirements.

Mentioned earlier, the Digital Privacy Act also introduces significant penalties for organizations that contravene these provisions. An organization that fails to notify affected individuals and the OPCC can be fined up to \$100,000 per violation. For now, it is uncertain whether "per violation" means each cyber incident or each individual not notified. If it is the latter, then the fines could be very high.

Statutory Framework: Provincial

Alberta, British Columbia and Quebec have legislation substantially similar to PIPEDA. In Ontario, New Brunswick, and Newfoundland and Labrador, privacy laws governing health care have been deemed substantially similar to PIPEDA.

However, in some provinces, provincial health privacy laws have been enacted but are not considered substantially similar to PIPEDA. In such cases, PIPEDA continues to apply. Furthermore, certain provinces such as Alberta and British Columbia have enacted privacy laws that specifically apply to employee information.

Provincial privacy laws govern issues such as:

- When information can be collected.
- How and when information may be disclosed or destroyed.
- Purposes for which information can be used.
- The type of notice required before information can be collected.
- When consent is required and how it is to be obtained.

[Click to Watch: PIPEDA for Business](#)

Criminal Law: Invasion of Privacy

Part VI of the Criminal Code contains provisions related to invasion of privacy: it holds an individual who willfully intercepts a private communication guilty of an indictable offence and liable to imprisonment for up to five years (Section 184). A court may also hold such an individual responsible for punitive damages (Section 194) and can seize the device used to intercept the private communication (section 192).

Separate offences have been created for the interception of cellular telephone communications, under sections 184.5 and 193.1. Under these sections, an individual who intercepts or discloses such private communication is guilty of an indictable offence and liable to imprisonment for a term of up to two years. The provisions only apply when a communication has been purposefully intercepted with a mechanical or other device, not when a communication is merely overheard by a third party and without a device.

Criminal Law: Mischief

Section 430 of the Criminal Code contains provisions related to crimes of mischief. Under section 430-1.1, an individual commits mischief when they alter or destroy computer data; obstruct or interfere with its lawful use; or deny access to a person who is entitled to access the data. An individual held culpable of such mischief is guilty of an indictable offence and is liable to imprisonment for a term of up to 10 years, or is guilty of an offence punishable on summary conviction.

Related to the provisions in Section 430, Section 420-5.1 states that anyone who willfully commits an act of mischief that is likely to cause danger to life, or creates mischief in relation to property or computer data, is guilty of an indictable offence and is liable to imprisonment for a term of up to five years or is guilty of an offence punishable on summary conviction. Furthermore, under Section 342.1(1) (c), an individual also commits an offence if they use a computer facility with intent to commit an offence.

These provisions were used recently to charge a University of Alberta student for installing malware on the university's computer systems. In November 2016, the IT staff at University of Alberta started receiving complaints about computer performance. Investigations revealed that malware had been installed on 204 computers by a student; approximately 3,323 computers belonging to or used by students and staff were infected by the malware. The student was charged with mischief related to computer data, unauthorized use of computer services, interception function of a computer system and use of computer facilities with intent to commit an offence.

Common Law: History

The legal landscape of Canadian privacy and cybersecurity law has changed dramatically in the last few years. In the past, when organizations experienced a cyber incident, they could notify the OPCC for a set of non-binding recommendations. Customers whose sensitive and personal information had been compromised seldom sought relief from the courts. Tort law for invasion of privacy was undeveloped and did not allow for adequate compensation to people who suffered the effects of a cyber incident: to bring a successful claim, plaintiffs had to prove that they had suffered an egregious harm such as identity theft. In cases where damages were awarded, they were trivial, with a maximum of \$5,000 awarded to individual claimants.

However, this changed in 2012 with the landmark decision of *Jones v Tsige*, which introduced the tort of “inclusion upon seclusion” and provided a relief mechanism to claimants whose privacy had been breached. *Jones v Tsige* not only paved the way for subsequent claims, but also marked the beginning of an expanding scope and basis of liability for claims of invasion of privacy.

Basic of Liability

In early 2012, the Ontario Court of Appeal rendered a landmark decision in *Jones v Tsige*. Jones brought an action for damages for invasion of privacy when her ex-husband’s common law partner, a Bank of Montreal employee, checked Jones’s bank account 174 times during a four-year period. Jones initially moved for summary judgment, and the motion judge dismissed the action because the tort of invasion of privacy did not exist at common law in Ontario.

However, when Jones appealed, the Ontario Court of Appeal held otherwise and awarded Jones damages of \$10,000. The Court of Appeal introduced a new tort for claims of invasion of privacy: “intrusion upon seclusion.” Where one intentionally intrudes upon the seclusion or private affairs of another, the intruder can be found liable if the following criteria are met:

1. The defendant’s conduct resulted in an invasion, without lawful justification, of the plaintiff’s affairs or concerns.
2. The defendant’s conduct was intentional or reckless.
3. A reasonable person would regard the invasion as highly offensive, causing distress, humiliation or anguish.

Plaintiffs are not required to demonstrate harm in order to succeed in their claim. In dicta, the Court held that the range of damages permitted in cases of intrusion upon seclusion should not exceed \$20,000.

The evolution of common law tort for claims of invasion of privacy did not stop at “intrusion upon seclusion.” Canadian courts were faced with a similar question in *John Doe v Canada*. In November 2003, more than 40,000 participants in the Marihuana Medical Access Program received notices from Health Canada that clearly displayed their names and the name of the program; this was an administrative error, contrary to Health Canada’s usual practice. Participants brought a privacy class-action claim based in negligence, breach of confidence, intrusion upon seclusion, and publicity given to private life.

In July 2015, the Federal Court released its order, granting the case class-action certification and stating that the novel claim of “publicity given to private life” should not be struck at that preliminary stage.

The Court acknowledged that the legal wrong was “truly novel in Canada” and cited Restatement of the Law (Second) of Torts, where the tort was described as follows:

One who gives publicity to a matter concerning the private life of another is subject to liability to the other for invasion of his privacy, if the matter publicized is of a kind that:

- a. Would be highly offensive to a reasonable person.
- b. Is not of a legitimate concern to the public.

The Government of Canada appealed the certification order, and in a judgment dated June 24, 2016, the Federal Court of Appeal confirmed the order for certification, but only with respect to the cause of action of negligence and breach of confidence. The cause of action of “publicity given to private life” was dismissed.

In early 2016, the Superior Court of Justice introduced the tort of “publicity given to private life” in *Jane Doe 464533 v N.D.* In this case, the defendant had posted an intimate video of the plaintiff on a pornographic website without her knowledge or consent.

The plaintiff brought a claim for invasion of privacy, breach of confidence, and intentional infliction of shock to the nervous system. She sought punitive and compensatory damages for the mental anguish, depression and reputational harm that she suffered as a result of the video being made public.

In analyzing the facts, Judge Stinson cited the American legal scholar William L. Prosser and noted that four different torts were required to serve different facts and protect different interests.

These torts are:

1. Intrusion upon the plaintiff’s seclusion or solitude, or into his private affairs.
2. Appropriation, for the defendant’s advantage, of the plaintiff’s name or likeness.
3. Public disclosure of embarrassing private facts about the plaintiff.
4. Publicity which places the plaintiff in a false light in the public eye.

While the tort of “inclusion upon seclusion” had been recently introduced in Canadian jurisprudence by the judgment of *Tsige v Jones* in 2012, in *Jane Doe 464533 v N.D.*, Judge Stinson held that the facts of this case could not be fully captured by this tort. He noted that the second category, public disclosure of embarrassing private facts about the plaintiff, was a more befitting category for the facts at hand.

1. The disclosure of the private facts must be a public disclosure, and not a private one.
2. The facts disclosed to the public must be private facts, and not public ones.
3. The matter made public must be one which would be offensive and objectionable to a reasonable man of ordinary sensibilities.

By introducing a new tort, *Jane Doe 464533 v N.D* recognized a distinct right of action for a breach of privacy when private facts are made public. It is noteworthy that this decision introduces two additional torts in its dicta, hence making it possible to incorporate them into mainstream jurisprudence when the appropriate facts are presented.

The damages awarded in this case are also noteworthy. This claim had been commenced under Simplified Procedure and was limited to a maximum amount of \$100,000. The judge awarded the plaintiff \$100,000

for breach of her dignity and personal autonomy; he also awarded pre-judgment interest in the amount of \$5,500, and \$36,228 for legal costs.

However, the defendant appealed, and in September 2016 Judge Dow set aside the findings of liability and assessment of damages upon payment by the defendant of costs of \$10,000. A motion to appeal brought by the plaintiff was denied by the Ontario Superior Court of Justice on January 9, 2017.

The expanding basis of liability for privacy claims is not limited to the introduction of new torts. In recent years, courts have also broadly interpreted the scope of certified privacy class actions by allowing additional causes of actions to proceed to trial. In *Condon v Canada*, the appellants—recipients of loans from the Canada Student Loans Program—brought a claim against the respondent, who had misplaced a hard drive containing the students’ personal information. The claim was based in negligence, breach of confidence, breach of contract and intrusion upon seclusion.

The judge granted a partial certification by only allowing claims of intrusion upon seclusion and breach of contract to be part of the class action proceeding: for claims of negligence and breach of confidence, the Federal Court held that they would fail for lack of compensable damages. The case was appealed to the Federal Court of Appeal in 2015, which confirmed the minimum evidentiary requirement at the certification stage of class actions in Canada. The Court held that the certification hearing does not involve an assessment of the merits of the claim.

Despite absence of any evidence that the appellants had suffered tangible loss, claims based in negligence and breach of confidence were to also proceed to trial. Hence, the basis of liability in privacy class action claims was further expanded in 2015, in *Condon v Canada*.

Scope of Liability

Depending on the nature of the attack, claims for invasion of privacy can be potentially brought by:

1. Victims
2. Financial Institutions
3. Shareholders

An organization or its directors can be held liable if the organization fails to take adequate and reasonable steps to secure its network and data. Courts can also hold an organization liable if it fails to mitigate risk once a cyber incident occurs.

Claims by Victims

Individuals whose personal information is compromised because of cyber incidents can bring claims against the organizations responsible for storing the information. Plaintiffs do not need to show that they suffered egregious or tangible harm. It is sufficient to show that the organization breached its duty and standard of care by failing to employ reasonable and adequate cybersecurity measures.

Plaintiffs can bring claims based in negligence, breach of confidence, intrusion upon seclusion and/or publicity given to private life. In *Tsige v Jones*, the Court of Appeal stated that given the intangible nature of the interest protected, the plaintiffs should not be awarded damages more than \$20,000 for claims

based in intrusion upon seclusion. *Jane Doe 464533 v N.D.*, the Court of Appeal awarded the plaintiff \$100,000 in damages, for the tort of “publicity given to private life.”

Damages awarded for common law torts of invasion of privacy may not be conclusively determined at this stage. However, organizations need to know that even a modest award can result in a large monetary liability during a class-action claim, if there are many claimants.

High-Profile Cases Brought by Individual Claimants in Canada

Target

In November 2013, Target experienced a data breach, exposing roughly 110 million customers’ information and at least 40 million customers’ payment cards. The breach happened on or around Black Friday and was discovered on December 13. A forensic team was hired to investigate the breach on December 15, but by then hackers had already stolen 11 gigabytes of data, containing the names, mailing addresses, phone numbers, email addresses and payment card information for up to 70 million people.

Target’s system had been compromised through a third-party supplier whose login credentials had been stolen through malware; these credentials were then used to infiltrate Target’s main system.

Canadian customers began class-action proceedings in Quebec, in *Zuckerman v Target Corporation*. The plaintiffs claimed damages for fear, stress, inconvenience, lost time and expense dealing with the issues stemming from the breach. The case was initially dismissed on jurisdictional grounds but was reversed on appeal and sent back for reconsideration.

In January 2017, the Quebec Superior Court granted the plaintiff’s motion and allowed for the class action in the district of Montreal.

Home Depot

Home Depot suffered a breach in September 2014, in which 56 million customers’ credit card information and 53 million email addresses were stolen. Hackers infiltrated Home Depot’s internal network by using login credentials of a third-party supplier. The stolen credentials alone did not provide direct access to Home Depot’s point-of-sale devices, but the hackers were able to use the initial access to run a privilege escalation attack. This attack allowed them to deploy custom-built malware on Home Depot’s self-checkout systems in the U.S. and Canada.

Canadian customers were also affected by the breach. Home Depot notified the Office of the Privacy Commissioner of Canada and their Canadian customers, telling them that customers’ personal information, along with credit and debit card information, might have been stolen.

Customers brought claims against Home Depot in Ontario and Saskatchewan. The action in Saskatchewan was stayed for the settlement approval motion to proceed in Ontario. The plaintiffs sought damages for the risk of fraudulent charges on their credit cards. Judge Paul Perell approved the settlement and awarded \$400,000 in damages and \$120,000 in legal fees.

Ashley Madison

Avid Life Media Inc. (ALM) is a Toronto-based firm that owns Ashley Madison and related websites such as Established Men. On July 15, 2015, hackers calling themselves “the Impact Team” infiltrated ALM’s network and stole 40 megabytes of sensitive data from 40 million accounts: customers’ names,

addresses, phone numbers, passwords and credit card information were made publicly available on the internet. Internal ALM documents such as maps of internal servers, employees' network account information, company bank account data and salary information were also compromised.

Exact details about how the Impact Team hacked into ALM's network are unknown. However, an inquiry by the Office of the Privacy Commission of Canada revealed that the website's security measures were inadequate and contravened federal laws. The inquiry also revealed that ALM had failed to employ "basic organizational security safeguards" to monitor unusual account logins, and lacked intrusion detection systems or intrusion prevention systems. ALM also did not have a risk management framework, nor did they implement multi-factor authentication, which is a standard industry practice.

In August 2015, a national class-action suit commenced against ALM in the Ontario Superior Court of Justice and the Superior Court of Quebec, on behalf of Quebec residents. The plaintiffs seek \$750 million in general damages and \$10 million in punitive damages for costs incurred to prevent identity theft, increased risk of identity theft, mental distress, emotional upset, anguish and reputational harm. Proceedings have commenced, but a final judgment is still pending.

Bank of Nova Scotia

In *Evans v The Bank of Nova Scotia*, from 2014, plaintiffs brought a privacy class action against the bank and an employee who had released plaintiffs' personal information to third parties for fraudulent purposes.

The plaintiffs' claim was based in negligence, breach of confidence, intrusion upon seclusion and breach of fiduciary duty. In the alternative, plaintiffs sought damages under "waiver of torts," where damages would be calculated by requiring the bank to surrender its profits during the relevant time period.

In early 2014, the Ontario Superior Court of Justice granted the action certification as a class action; a final resolution is pending.

Casino Rama

On November 10, 2016, Casino Rama resorts in Rama, Ontario, announced that its internal computer network had been breached, and that its customers', employees', and suppliers' personal and financial information from 2004 to 2016 was stolen. Exact details of the breach are still unknown.

In *Leonid Kaplin and Cheryl Jane Mizzi v Casino Rama Services Inc.*, the plaintiffs seek \$50 million, and \$10 million in punitive damages. The plaintiffs also seek a declaration that Casino Rama owed them a duty of care and breached their standard of care. The notice of action was filed on November 14, 2016, on behalf of all Canadian residents whose private information had been stolen. A final resolution of this claim is pending.

Yahoo

On September 22, 2016, Yahoo confirmed that its system had been breached in late 2014 and that 500 million users' account information had been hacked. A few months later, in December 2016, Yahoo announced that over one billion users' account information had been stolen in a separate attack in August 2013. The compromised information included names, email addresses, phone numbers, passwords and birthdates. Yahoo stated that the attacks were conducted by a "state-sponsored" party that used forged cookies to access users' accounts by impersonating the true owner of each account.

A notice of action for a proposed class action was filed in December 2016. The notice of action asserts that Yahoo knew about the breach months before they announced it, and that as many as eight million Canadians were affected.

The claim, which has yet to be certified as class action, is based on breach of contract, invasion of privacy, intrusion upon seclusion and unjust enrichment. The plaintiffs seek \$50 million in damages along with \$10 million in punitive damages. A final resolution of this claim is pending.

Claims by Financial Institutions

In the wake of a cyber incident, claims are often brought by banks and other financial institutions, to regain the cost of reissuing debit and credit cards. The following examples show how companies have settled lawsuits with financial institutions in the United States.

Tjx Companies, Inc.

In 2004, a consortium of major credit card companies including American Express, Visa and MasterCard created a Payment Card Industry Data Security Standard (PCI DSS), establishing an industry standard to which all companies that process credit card payments should adhere.

Over the next two years, TJX Companies, Inc. (TJX), the parent company of retailers T.J. Maxx and Marshalls, failed to comply with PCI DSS, with its Chief Information Officer, Paul Butka, choosing to not upgrade their systems to Wi-Fi Protected Access (WPA) technology.

In early 2006, cybercriminals hacked into TJX's system and stole customers' credit and debit card information. TJX's system had been compromised for up to a year before the breach was discovered.

In January 2007, TJX announced the breach, revealing that 46 million customers' information was stolen. The cyber incident was carried out by a known cybercriminal; however, blame was laid on the retailers' IT executives, who had failed to upgrade their security measures as per industry practices.

In October 2007, a group of banks brought a claim against TJX, alleging that 65 million Visa account numbers and 29 million MasterCard numbers had been compromised, twice as many as announced by TJX. The banks alleged that TJX had mishandled its security and should therefore reimburse the banks for the cost of reissuing compromised credit cards. The banking plaintiffs did not quote an exact amount for the damages they sought. However, TJX agreed to settle within a few days: it agreed to pay Visa U.S.A. Inc. and Visa Inc. \$40.9 million USD (before taxes) in alternative recovery payments.

A few months later, in April 2008, TJX settled MasterCard's claims by agreeing to pay \$24 million USD, bringing the total amount spent by TJX in settling claims with financial institutions to nearly \$65 million USD.

Target

Facts of the case have been outlined previously. Claims brought by financial institutions were consolidated in Re: Target Corporation Customer Data Security Breach Litigation, U.S. District Court, District of Minnesota. There were several plaintiffs, including Mutual Bank in Whitman. Damages were sought for costs incurred in reissuing new credit and debit cards, reimbursing customers for fraudulent charges, monitoring customer accounts for fraudulent activity, addressing customer confusion and complaints, and changing or cancelling accounts.

The plaintiffs claimed that these costs could have been easily avoided if Target had taken adequate and reasonable steps to protect its data and information systems. In August 2014, the lawsuit was settled, and Target agreed to pay \$39.04 million USD (\$20.25 million USD to class members and an additional \$19.1 million USD to MasterCard). The settlement terms also included a legal fee of \$17.8 million USD.

Home Depot

The facts of the case are mentioned earlier in this module. In May 2014, financial institutions brought a consolidated class-action suit against Home Depot for failing to protect consumer data. In *Re: The Home Depot, Inc. Customer Data Breach Litigation*, the plaintiffs sought damages from Home Depot for costs incurred in reissuing credit and debit cards, paying for fraudulent transactions, credit monitoring and freezing credit reports. In March 2016, the court approved the creation of a settlement fund, worth \$13 million USD.

Claims by Shareholders

In the event of a cyber incident, an organization's shareholders can bring a claim against directors and officers for breaching their fiduciary duty. Such claims usually seek damages for mismanagement and not for breach of privacy. No such claim has been filed in Canada yet, but many examples can be found in the United States. Two recent high-profile cases are those of Target and Wendy's.

Target

In 2014, Target's shareholders brought six derivative action suits against its directors and officers. The actions were consolidated in the District Court of Minnesota; the plaintiffs alleged that the company had "failed to properly provide for and oversee an information security program" and "failed to give customers prompt and accurate information in disclosing the breach." The shareholders demanded a change in management and to be paid damages resulting from regulatory investigations and defending various class-action suits.

Under Minnesota law, federal courts defer to a corporation's special litigation committee to dismiss a derivative action if the committee can demonstrate independence and good faith in investigating the claims. Target's Board of Directors formed such a Special Litigation Committee ("Committee") to investigate and evaluate the claims asserted in the derivative actions.

After 21 months of research, the Committee concluded that it was not in the best interests of the shareholders to pursue this action. The shareholders did not challenge this finding, and the action was dismissed in July 2016 by Judge Paul Magnuson.

While Target's derivative action was dismissed based on certain procedural hurdles, future claims could still be pursued. Plaintiffs' lawyers have been resilient in finding ways to hold management responsible for cyber-related claims.

Wendy's

The Wendy Company ("Wendy's") is an American-based fast-food restaurant chain. In early 2016, it discovered malware on its systems, which had been installed using login credentials gleaned from a third-party connection. An investigation revealed that the malware affected point of sale systems at more than 300 restaurants.

Wendy's soon faced claims by victims, financial institutions and shareholders. The plaintiff shareholder who filed a derivative action premised his claim on breach of fiduciary duty, waste of corporate assets, unjust enrichment and gross mismanagement, seeking recovery of damages, reform of corporate governance and restitution of benefits.

Kevin LaCroix, a commentator on derivative actions in the United States, argues that previous derivative actions in cyber-related litigation have failed only because of procedural issues. One such issue is when the plaintiffs "fail to make a pre-suit demand on the company's board of directors." However, in the current action against Wendy's, this procedural issue is addressed. The claim argues the futility of a demand on the board, and notes that the defendant shareholders hold a majority of interest in Wendy's and have familial ties with one another.

While a final resolution of this action is pending, a derivative claim against Wendy's could soon be successful, due to the enterprising nature of the plaintiffs in holding the organization monetarily responsible for not taking reasonable and adequate steps to protect against cyber incidents.

Module Summary

In this module you have learned:

1. The privacy and cybersecurity landscape in Canada has shifted dramatically in recent years, with both legislative changes and changes in the interpretation of existing laws. With the passage of the Digital Privacy Act, organizations that use, collect or store personal information have breach notification and reporting obligations.
2. Cyber incidents need to be reported to affected individuals and the Privacy Commissioner. Once the "significant harm" threshold is met, records of all instances of breach must be retained.
3. The confidentiality provision of PIPEDA has been amended to allow the Privacy Commissioner to publicize cyber incidents if it serves the public interest. Organizations that contravene PIPEDA face severe financial and reputational penalties.
4. The court cases *Jones v Tsige* and *Jane Doe 464533 v N.D.* introduced new torts related to privacy that have increased privacy-related litigation, as claimants now have certainty in terms of judicial recourse.
5. Common law provides a mechanism for grievance redressal; it also awards a predictable amount of damages.
6. For the tort of "inclusion upon seclusion," damages of up to \$20,000 can be expected, whereas for the tort of "publicity given to private life," damages as high as \$100,000 have been awarded.

Knowledge Check

The following questions provide an opportunity for you to see what you remember and understand so far. Answer the questions to the best of your ability.

1. **Organizations that store and collect personal information are the only victims of cybersecurity incidents.**
 - a. True
 - b. False
2. **Once information is stolen, it is:**
 - a. Sold on the "dark web" for use in fraudulent uses

- b. Held for ransom
 - c. Used to create physical destruction of corporate assets
 - d. All of the above
3. The two new torts of privacy are “intrusion upon seclusion” and “publicity given to private facts.”
- a. True
 - b. False
4. Certain provinces have privacy legislation deemed “substantially similar” to PIPEDA. In these cases, provincial legislation applies instead of PIPEDA.
- a. True
 - b. False
5. Depending on the nature of the attack, claims for invasion of privacy can be potentially brought by victims, financial institutions and shareholders.
- a. True
 - b. False
6. Liability for the organization or its directors can arise if the organization failed to take adequate and reasonable steps to secure its network and protect its data.
- c. True
 - d. False
7. Where one intentionally intrudes upon the seclusion or private affairs of another, the intruder will be subject to liability if the following criteria are met:
- The defendant’s conduct was intentional or reckless.
 - It resulted in an invasion, without lawful justification, of the plaintiff’s affairs or concerns.
 - Reasonable persons would regard the invasion as highly offensive, causing distress, humiliation, or anguish.
- a. True
 - b. False
8. The Digital Privacy Act amends PIPEDA.
- a. True
 - b. False

Answers:

- 1. The answer is false because organizations that use personal information are also victims of cybersecurity incidents.
- 2. All of the above
- 3. True
- 4. True
- 5. False
- 6. True
- 7. True
- 8. True

You have completed: Roles of Contracts and Contract Issues

Remember to check the timeline before you proceed to the next module to ensure you have completed any assignments as required. Check with your instructor if you have any questions.